Calnivo Privacy & Consent Audit — Fix Report

Actionable issue list with a short implementation prompt for your coding agent

Project	Calnivo — https://calnivocalc.com/
Repository	https://github.com/mohammedtech121/Calnivo
Audit date	22 October 2026
Scope	Consent banner, GA4 loader, privacy policy, public copy, terms/disclaimer, accessibility and verification steps.

Overall verdict

The current implementation has a useful foundation: GA4 is intended to load only after an accept decision, and the policy explains analytics and hosting separately. However, source review identified a consent-withdrawal defect, inconsistent “no data collected” wording, unequal button emphasis, policy precision gaps, and missing live-browser verification. Fix the P0 items first.

Priority key: P0 = fix first; P1 = important; P2 = polish/verification. These are engineering/trust priorities, not a formal legal finding.

1. Findings and required fixes

01. Analytics may continue after consent withdrawal

P0 — Critical | **Files:** src/components/layout/ConsentBanner.tsx; src/components/layout/AnalyticsLoader.tsx

Finding: The privacy-settings reset removes the localStorage value and reopens the banner, but AnalyticsLoader checks consent only once on mount. If GA4 has already loaded, changing the preference does not reliably update the loader or stop existing analytics activity.

Required fix: Use a single reactive consent state shared by the banner and analytics loader. On withdrawal, immediately disable further GA4 collection/events and prevent reloading until consent is granted again. Do not treat deleting localStorage alone as withdrawal handling.

Verification: Accept analytics, confirm GA4 requests; open Privacy settings and withdraw; verify no further analytics events/requests are sent. Test navigation without a full reload.

02. Contradictory “no data collected” claims

P0 — Critical | **Files:** src/app/calculators/page.tsx and any homepage/metadata/marketing copy

Finding: The calculator directory still says “no data collected” even though the policy says GA4 may collect usage information and Netlify may log request metadata. The latest commit message claims this phrase was removed everywhere, but the fetched source still contains it.

Required fix: Search the entire repository for “no data collected”, “no tracking”, “we collect no data”, and equivalent absolute claims. Replace inaccurate copy with a truthful statement distinguishing calculator inputs from analytics/hosting data.

Verification: Search repository-wide and inspect the deployed homepage, /calculators, page metadata, and social previews after deployment.

03. Accept button is visually preferred over Reject

P1 — High | **Files:** src/components/layout/ConsentBanner.tsx

Finding: Accept analytics uses a gradient, shadow, and hover-scale effect; Reject is plain white with a border. This creates unequal visual emphasis and may steer visitors toward acceptance.

Required fix: Give Accept analytics and Reject optional analytics equal prominence, accessible contrast, similar size, and visible focus. Remove the extra hover-scale effect from Accept. Avoid preselected or implied default choices.

Verification: Review on mobile and desktop, keyboard-tab through both choices, and confirm neither choice is hidden or harder to use.

04. Privacy policy overstates aggregation

P1 — High | **Files:** src/app/privacy/page.tsx

Finding: The policy describes GA4 collection as “basic, aggregate usage statistics,” then lists page visits, duration, region, browser, and referral source. That wording can suggest GA4 receives only pre-aggregated data.

Required fix: Describe GA4 as processing usage and technical information to generate reports. State the purpose, examples of data, Google's role, and consent choice without claiming that all collected information is anonymous or pre-aggregated.

Verification: Compare the text with the actual GA4 configuration and Google's current documentation; do not promise collection limits that are not configured.

05. Local-storage consent choice is not clearly disclosed

P1 — High | **Files:** src/components/layout/ConsentBanner.tsx; src/app/privacy/page.tsx

Finding: The decision is saved under localStorage key calnivo:consent, but the policy does not clearly tell visitors that their preference is stored in browser local storage.

Required fix: Add a short policy explanation that Calnivo saves the analytics preference in local storage to remember the visitor’s choice. Distinguish this from GA cookies and do not claim no browser storage is used.

Verification: Confirm the description matches the implementation and that rejecting analytics does not load GA4.

06. No independent proof that pre-consent requests are blocked

P1 — High | **Files:** src/components/layout/AnalyticsLoader.tsx; src/app/layout.tsx; deployed site

Finding: The source is designed to block GA4 until consent, but source inspection alone cannot prove the deployed build sends no pre-consent analytics requests or that all calculator inputs remain client-side.

Required fix: Run clean-session browser tests and inspect network traffic before consent, after reject, after accept, and after withdrawal. Check event parameters, page URLs, and third-party requests for calculator values or sensitive inputs.

Verification: Save test results/screenshots. Confirm no GA4 requests before acceptance and no calculator inputs/results in analytics events or URLs.

07. Retention and operator details need verification

P1 — High | **Files:** src/app/privacy/page.tsx

Finding: The policy delegates retention to GA4 property settings and Netlify policies and gives an email contact but limited operator identity details. These may be acceptable in some contexts, but should be checked against the actual setup and applicable laws.

Required fix: Verify the GA4 retention setting and hosting configuration; publish accurate retention details where appropriate. Review whether the policy should identify the responsible operator/business and provide any jurisdiction-specific disclosures required for the audience.

Verification: Record the actual GA4 retention configuration and confirm the operator/contact details are accurate. Seek qualified legal advice for jurisdiction-specific obligations.

08. Consent banner accessibility needs a pass

P2 — Medium | **Files:** src/components/layout/ConsentBanner.tsx

Finding: The banner has role=dialog and an accessible label, but no explicit aria-modal or focus-management behavior is implemented. The correct semantics depend on whether it is intended as a blocking dialog or a non-blocking banner.

Required fix: Choose appropriate banner/dialog semantics, ensure clear accessible naming, keyboard operation, visible focus, screen-reader announcements, and sensible focus behavior. Add aria-modal only if the component truly behaves as a modal.

Verification: Test keyboard-only use, screen-reader behavior, zoom, and narrow mobile screens.

09. Google consent/ad requirements need a region-specific check

P1 — High | **Files:** Analytics and future advertising configuration; policy

Finding: A custom GA4 banner does not by itself prove compliance with every applicable Google policy or privacy law. Requirements can vary by audience location and by whether analytics or advertising technologies are used.

Required fix: Check current Google requirements for the regions Calnivo serves and the exact GA4 setup. If Google advertising is added, separately review ad-cookie disclosures and certified CMP requirements where applicable. Do not assume all visitors are governed by identical rules.

Verification: Document the target regions, services enabled, consent mode configuration, and any applicable CMP requirements before claiming compliance.

10. Terms date and tax disclaimer may be stale

P2 — Medium | **Files:** src/app/terms/page.tsx; src/app/disclaimer/page.tsx; relevant tax calculator implementation

Finding: Terms show August 2026 while the privacy policy shows October 2026. The disclaimer says tax calculators use 2024 IRS federal brackets for taxes filed in 2025, which may be outdated for a site being audited in October 2026.

Required fix: Review whether terms changed with the product and update dates only when the content is actually reviewed. Verify the tax calculator's real data/formula and clearly label its supported tax year; update calculations if current-year use is intended.

Verification: Compare tax formula/constants with authoritative IRS material and test representative values before changing claims.

2. Short prompt for your coding agent

Copy this prompt into your coding agent while the Calnivo repository is open. It asks the agent to fix all identified issues without making unrelated changes.

Act as a senior Next.js/TypeScript privacy, consent, accessibility, and QA engineer. Audit and FIX the issues in this repository, especially ConsentBanner.tsx, AnalyticsLoader.tsx, src/app/privacy/page.tsx, src/app/calculators/page.tsx, src/app/terms/page.tsx, src/app/disclaimer/page.tsx, and any related site-wide copy. Requirements: 1. Fix consent withdrawal: make consent state reactive/shared; when a visitor withdraws consent, immediately stop further GA4 collection/events and prevent analytics from running unless consent is granted again. Do not rely on deleting localStorage alone. Avoid duplicate GA4 initialization. 2. Make the consent UI neutral: “Accept analytics” and “Reject optional analytics” must be equally visible and accessible; remove visual nudges such as a stronger gradient/shadow/scale effect on Accept. 3. Search the entire repository for inaccurate absolute claims such as “no data collected”, “no tracking”, or equivalent. Replace them with truthful wording that distinguishes local calculator inputs from analytics and hosting metadata. 4. Improve the Privacy Policy: accurately describe GA4 data processing (do not imply it only receives pre-aggregated or fully anonymous data), disclose that the consent preference is stored in localStorage, explain purpose and third-party processing, and verify retention/operator details rather than inventing them. 5. Verify calculator input privacy in code and outbound analytics events/URLs. Never send calculator inputs, results, financial/health values, generated passwords, or other sensitive values to GA4. Do not make absolute claims unless verified. 6. Review banner semantics and accessibility: keyboard navigation, focus visibility, accessible name, screen-reader behavior, mobile layout, and appropriate dialog/banner semantics. 7. Review applicable current Google consent requirements for the services and regions actually targeted. Do not claim legal compliance without evidence; do not add an advertising CMP unless the actual services/requirements call for it. 8. Review terms/disclaimer dates and verify the tax calculator’s supported tax year against its actual implementation and authoritative data. Do not change formulas blindly. 9. Keep changes scoped; preserve the existing design system and calculator behavior. Do not remove features or refactor unrelated code. After changes: run lint, typecheck if available, and production build. Report files changed, exact behavior changes, test results, any unresolved legal/configuration questions, and a manual browser test checklist. If a requirement cannot be verified from code, clearly label it as requiring a live deployment or owner configuration check. Do not claim success for tests that were not run.

3. Manual test checklist after deployment

Test	Expected check
Fresh visit / no stored choice	Clear localStorage and site data. Open the site. Confirm both choices are visible and equally prominent. Confirm no GA4 network request occurs before acceptance.
Reject	Click Reject optional analytics. Navigate between calculator pages and reload. Confirm the rejection is remembered and GA4 requests do not occur.
Accept	Clear site data, accept analytics, and confirm GA4 loads once. Check that no calculator input/result values are sent in event parameters or URLs.
Withdraw	Use footer Privacy settings after accepting. Withdraw/reject. Confirm new GA4 requests/events stop without needing the visitor to manually clear storage.
Calculator privacy	Test financial, health, password, and other calculator pages. Inspect network requests and query strings for sensitive values.
Public copy	Check homepage, /calculators, /privacy, /terms, and /disclaimer on the deployed domain. Confirm claims and dates match the current implementation.
Accessibility	Test keyboard-only navigation, focus visibility, screen reader labels, mobile viewport, and browser zoom.
Build and release	Run lint, typecheck if available, and production build. Deploy and repeat the live checks on the production domain.

4. Source references

Repository: https://github.com/mohammedtech121/Calnivo

Consent banner: https://github.com/mohammedtech121/Calnivo/blob/main/src/components/layout/ConsentBanner.tsx

Analytics loader: https://github.com/mohammedtech121/Calnivo/blob/main/src/components/layout/AnalyticsLoader.tsx

Privacy policy source: https://github.com/mohammedtech121/Calnivo/blob/main/src/app/privacy/page.tsx

Calculator directory source: https://github.com/mohammedtech121/Calnivo/blob/main/src/app/calculators/page.tsx

Latest privacy-fix commit reviewed:
https://github.com/mohammedtech121/Calnivo/commit/2ae0a2a18ce65a0094e57f9703844f4566603807

Live privacy policy: https://calnivocalc.com/privacy

Live terms: https://calnivocalc.com/terms

Live disclaimer: https://calnivocalc.com/disclaimer

Google partner-site privacy explanation: https://policies.google.com/technologies/partner-sites?hl=en-IN

Google publisher privacy policy guidance: https://support.google.com/publisherpolicies/answer/10437794?hl=en

Google consent mode overview: https://developers.google.com/tag-platform/security/concepts/consent-mode

Important limitation: This report is based on source-code review and the audit observations available at the time of writing. A complete compliance conclusion requires live network testing, confirmation of deployed code/configuration, and review of laws applicable to Calnivo's users. This document is not legal advice.